

Flashcard Deck

COMPANION DIGITAL PACKAGE

Flashcard Deck

100 exam-critical terms · Print, cut, and study

Term on front · Definition on back · 4 cards per printed page Print double-sided for best results

Mastering Identity Security for CIDPro™ | Abbas Kudrati | 2026

100
Flashcards

5
Colour-Coded Objectives

4
Cards per Page

25
Pages

Print double-sided: Print this PDF double-sided (flip on short edge). Each page of fronts will automatically align with the matching page of backs.

Cut along the lines: Each page has 4 cards. Cut along the grid lines to create individual study cards.

Colour coding: Cards are colour-coded by CIDPro™ objective: Navy = Obj 1 · Teal = Obj 2 · Blue = Obj 3 · Green = Obj 4 · Purple = Obj 5.

Study method: Work through front-to-back. If you answer correctly three times in a row, move the card to the 'known' pile. Revisit the remaining cards.

Exam focus: Cards are ordered from most-tested to supporting concepts within each objective area. Cards #1–30 cover the highest-frequency exam topics.

CIDPro™

Authentication

#002

CIDPro™

Authorisation

CIDPro™

#004

CIDPro™

© Abbas Kudrati | Mastering Identity Security for CIDPro™ | D-9: Flashcard Deck | Page 4

#005	CIDPro™	#006	CIDPro™
Attribute		Principal	

#007

CIDPro™

Credential

#008

CIDPro™

Federation

CIDPro™

CIDPro™

© Abbas Kudrati | Mastering Identity Security for CIDPro™ | D-9: Flashcard Deck | Page 7

#011 CIDPro™ IAL — Identity Assurance Level	#012 CIDPro™ AAL — Authenticator Assurance Level

#015CIDPro™Subscriber	#016CIDPro™Claimant

#017 CIDPro™ CSP — Credential Service Provider	#018 CIDPro™ Relying Party (RP)

CIDPro™

CIDPro™

© Abbas Kudrati | Mastering Identity Security for CIDPro™ | D-9: Flashcard Deck | Page 12

#021

CIDPro™

Presentation attack

#022

CIDPro™

Synthetic identity fraud

#023CIDPro™ KBA — Knowledge-Based Authentication	#024CIDPro™ Re-proofing

CIDPro™

Binding

CIDPro™

Authentication factor

#027CIDPro™ MFA — Multi-Factor Authentication	#028CIDPro™ FIDO2

#029

CIDPro™

Passkey

#029

CIDPro™

Passkey

#030

CIDPro™

Phishing-resistant MFA

#030

CIDPro™

Phishing-resistant MFA

CIDPro™

MFA fatigue attack

CIDPro™

Number matching

#033

CIDPro™

Step-up authentication

#034

CIDPro™

Adaptive authentication

#035 CIDPro™ WebAuthn	#036 CIDPro™ RBAC — Role-Based Access Control

#037

CIDPro™

ABAC — Attribute-Based Access Control

#038

CIDPro™

PBAC — Policy-Based Access Control

CIDPro™

CIDPro™

© Abbas Kudrati | Mastering Identity Security for CIDPro™ | D-9: Flashcard Deck | Page 22

#041 CIDPro™ JIT — Just-in-Time access	#042 CIDPro™ Zero Standing Privileges (ZSP)

CIDPro™

Bearer token

Symmetric encryption

#047CIDPro™ Asymmetric cryptography	#048CIDPro™ Digital signature

#049

CIDPro™

PKI — Public Key Infrastructure

#050

CIDPro™

TLS — Transport Layer Security

CIDPro™

Hashing

Salt

#053CIDPro™ JWT — JSON Web Token	#054CIDPro™ HSM — Hardware Security Module

CIDPro™

X.509

SAML 2.0

CIDPro™

OIDC — OpenID Connect

CIDPro™

SCIM

CIDPro™

LDAP

NIST SP 800-63-4

CIDPro™

CAEP

CIDPro™

DPoP

CIDPro™

Verifiable Credential (VC)

CIDPro™

SPIFFE/SPIRE

#065

CIDPro™

OAuth 2.1

#066

CIDPro™

AiTM — Adversary-in-the-Middle

#067

CIDPro™

Credential stuffing

#068

CIDPro™

Account takeover (ATO)

CIDPro™

CIDPro™

© Abbas Kudrati | Mastering Identity Security for CIDPro™ | D-9: Flashcard Deck | Page 37

CIDPro™

Lateral movement

CIDPro™

Privilege escalation

CIDPro™

Session hijacking

CIDPro™

STRIDE

#075 CIDPro™ Identity attack chain	#076 CIDPro™ GDPR

#077 CIDPro™ Data minimisation	#078 CIDPro™ Privacy by Design

#079

CIDPro™

Data Protection by Design

#080

CIDPro™

DPIA — Data Protection Impact Assessment

#081

CIDPro™

**IGA — Identity Governance &
Administration**

#082

CIDPro™

Access certification

CIDPro™

SoD exception

CIDPro™

SOC 2 Type II

#085CIDPro™ Residual risk	#086CIDPro™ PAM — Privileged Access Management

#087 CIDPro™ Credential Vault	#088 CIDPro™ PAW — Privileged Access Workstation

#089

CIDPro™

Session recording

#090

CIDPro™

**ITDR — Identity Threat Detection &
Response**

#091

CIDPro™

**UEBA — User & Entity Behaviour
Analytics**

#092

CIDPro™

SOAR

CIDPro™

Dwell time

CIDPro™

IDEAL Framework

CIDPro™

APEX

CIDPro™

NHI — Non-Human Identity

CIDPro™

Agentic AI

CIDPro™

Prompt injection

CIDPro™

Shadow AI

CIDPro™

Secrets management

Answer Side — Definitions

Print the following pages on the reverse side of the card-front pages. When cut, each card will have the term on the front and definition on the back.

Identity#003	Digital identity#004
The set of attributes that define and distinguish one entity — person, org, or device — from all others in a context.	An electronic representation of a real-world entity enabling it to be identified and authenticated in digital systems.

Authentication#001	Authorisation#002
The process of verifying that a claimant is genuinely the identity they claim to be. Answers: 'Who are you?'	The process of determining what a verified identity is permitted to access or do. Answers: 'What can you do?'

Credential#007	Federation#008
An object or data structure that authoritatively binds an identity to one or more authenticators held by the subscriber.	An architecture enabling users from one identity domain to access resources in another domain using their existing credentials.

Attribute#005	Principal#006
A piece of information associated with a digital identity: name, email, job title, department, or clearance level.	An entity — human or non-human — that can be authenticated and authorised within an identity system.

IAL — Identity Assurance Level	AAL — Authenticator Assurance Level
#011 NIST 800-63 measure of proofing strength. IAL1 = self-asserted · IAL2 = verified (remote or in-person) · IAL3 = in-person + mandatory biometric.	#012 NIST 800-63 measure of authentication strength. AAL1 = single factor · AAL2 = two factors + cryptography · AAL3 = hardware-bound key.

Single Sign-On (SSO) #009	Zero Trust #010
An authentication architecture where one authentication event grants access to multiple connected applications without re-authentication.	Architecture principle (NIST SP 800-207): no implicit trust based on network location. Every request evaluated individually.

Subscriber#015	Claimant#016
A party who has successfully completed identity proofing with a CSP and holds an issued credential.	What a subscriber becomes at the point of authentication — presenting credentials to be verified.

FAL — Federated Assurance Level	#013	Applicant	#014
NIST 800-63 measure of federation assertion strength. FAL1 = signed bearer · FAL2 = encrypted assertion · FAL3 = key possession proof.		A subject undergoing identity proofing who has submitted a claimed identity but has not yet been verified.	

Identity proofing#019	Liveness detection#020
The CSP process of collecting, validating, and verifying information about a person to establish a trusted digital identity.	A technique in remote biometric proofing confirming the sample is from a live person, not a static image or video.

CSP — Credential Service Provider	#017	Relying Party (RP)	#018
A trusted entity that conducts identity proofing and issues credentials to subscribers.		An application or service that consumes authentication assertions from a verifier to make access decisions.	

KBA — Knowledge-Based Authentication#023	Re-proofing#024
Verifying identity through personal knowledge questions. Static KBA is insufficient above IAL1 due to breach data exposure.	A repeated identity proofing event — triggered by policy renewal, life events, assurance escalation, or credential compromise.

Presentation attack#021	Synthetic identity fraud#022
Attempting to defeat a biometric system using a photograph, video, or mask instead of the real person.	Constructing a fictitious identity from real + fabricated attributes; no single real person is the underlying subject.

MFA — Multi-Factor Authentication	FIDO2
Authentication using two or more factors from different categories.	The FIDO Alliance open standard for passwordless, phishing-resistant authentication. Comprises WebAuthn (W3C) + CTAP (FIDO Alliance).

Binding#025	Authentication factor#026
Associating a verified identity with one or more authenticators, creating a durable link for future authentication.	A category of evidence: something you KNOW (password) · something you HAVE (key/phone) · something you ARE (biometric).

MFA fatigue attack#031	Number matching#032
Sending repeated push authentication requests until the user approves one. Also called prompt bombing. Mitigated by number matching.	MFA control requiring the user to match a code shown in the push request to one on their device, defeating fatigue attacks.

Passkey#029	Phishing-resistant MFA#030
A FIDO2 discoverable credential synced across devices. Synced passkeys = AAL2 · Device-bound passkeys = AAL3 (NIST SP 800-63-4).	MFA that cannot be defeated by real-time phishing because the credential response is cryptographically bound to the legitimate domain.

WebAuthn#035	RBAC — Role-Based Access Control#036
The W3C/FIDO Alliance browser API enabling Relying Parties to accept FIDO2 credentials.	Permissions bundled into named roles representing job functions. Users assigned to roles, not permissions directly.

Step-up authentication	Adaptive authentication
#033 Mid-session escalation requiring stronger authentication before a higher-risk action is permitted.	#034 Authentication that dynamically adjusts the challenge based on real-time risk signals: location, device, behaviour.

Least privilege#039	Separation of Duties (SoD)#040
Every identity should have access only to the minimum permissions required for its function — and no more.	No single identity holds permissions sufficient to complete a sensitive transaction unilaterally without independent review.

ABAC — Attribute-Based Access Control	PBAC — Policy-Based Access Control
#037 Access decisions based on attributes of the user, resource, action, and environment. Enables fine-grained contextual decisions.	#038 Access decisions expressed as formal structured policies evaluated by a policy engine, combining attributes and contextual logic.

OAuth 2.0 #043	Scope #044
IETF RFC 6749 authorisation framework for delegated API access. Does NOT perform authentication — that requires OIDC.	In OAuth 2.0, a string defining the specific subset of a protected resource a client application is authorised to access.

JIT — Just-in-Time access	#041	Zero Standing Privileges (ZSP)	#042
Elevated permissions granted on demand for a specific purpose with automatic expiry. Eliminates standing privilege.		No elevated privileges exist at rest. All privilege granted on-demand and revoked immediately after. Most advanced JIT model.	

Asymmetric cryptography	#047	Digital signature	#048
Mathematically related key pairs (public + private). What one encrypts, only the other decrypts. Foundation of PKI, TLS, FIDO2.		Cryptographic mechanism providing authenticity, integrity, non-repudiation. Created with private key; verified with public key.	

Bearer token#045	Symmetric encryption#046
An OAuth 2.0 access token whose possession alone is sufficient to access the protected resource.	Same key for encryption and decryption. Fast; used for data at rest (AES-256). Vulnerable to key distribution problem.

Hashing	#051	Salt	#052
One-way function converting input to a fixed-length digest. Used for password storage and integrity verification. Cannot be reversed.		A unique random value added to a password before hashing. Ensures identical passwords produce different hashes. Defeats rainbow tables.	

PKI — Public Key Infrastructure	TLS — Transport Layer Security
#049 System of standards and technologies supporting secure management and exchange of public keys through CAs and digital certificates.	#050 Cryptographic protocol securing data in transit. Every HTTPS connection uses TLS. Minimum TLS 1.2 required; TLS 1.3 preferred.

X.509#055	SAML 2.0#056
ISO standard defining the format of public key certificates used in PKI, TLS, and digital signatures.	OASIS XML-based federation standard for enterprise SSO. IdP issues signed XML assertions consumed by Service Providers.

JWT — JSON Web Token#053	HSM — Hardware Security Module#054
RFC 7519 compact token: Base64URL-encoded header + payload + signature. Used for ID tokens and access tokens in OIDC/OAuth 2.0.	Tamper-resistant hardware that stores cryptographic keys and performs operations without exposing key material.

LDAP#059	NIST SP 800-63-4#060
RFC 4510 protocol for querying and managing directory services. Foundation of enterprise directory environments.	Final (July 2025) Digital Identity Guidelines. Introduces DIRM framework, recognises synced passkeys as AAL2, endorses digital wallets.

OIDC — OpenID Connect	SCIM
Authentication protocol built on OAuth 2.0. Adds the ID token (signed JWT with identity claims) enabling SSO and federated auth.	RFC 7643/7644 RESTful standard for automated user provisioning and deprovisioning across systems when identity events occur.

Verifiable Credential (VC) #063	SPIFFE/SPIRE #064
W3C standard for cryptographically verifiable digital credentials held and presented by the subject.	CNCF framework for cryptographic workload identity. SPIFFE defines the SVID credential format; SPIRE issues certificates to workloads.

CAEP	#061	DPoP	#062
Continuous Access Evaluation Profile. OpenID Foundation spec for real-time security event signals enabling near-instant session revocation.		RFC 9449 OAuth extension making access tokens sender-constrained by binding them to the client's private key. Defeats token replay.	

Credential stuffing#067	Account takeover (ATO)#068
Automated attack testing breach-database username/password pairs against live services, exploiting password reuse.	Attacker obtains control of a legitimate user's account and can act as that user.

OAuth 2.1	#065	AiTM — Adversary-in-the-Middle	#066
IETF draft consolidating OAuth 2.0 best practices: PKCE mandatory, Implicit + ROPC grants removed, bearer tokens banned from URL params.		Phishing technique using a reverse proxy to capture credentials AND session cookies in real time. Bypasses TOTP MFA; defeated by FIDO2.	

Lateral movement#071	Privilege escalation#072
Attacker uses a compromised account to reach additional systems beyond the initial foothold.	Gaining access rights beyond what was authorised. Vertical = higher level · Horizontal = same level, different account.

Pass-the-Hash#069	Golden Ticket#070
Windows lateral movement: attacker uses a captured NTLM hash to authenticate to systems without knowing the plaintext password.	Active Directory attack: attacker with KRBTGT hash forges Kerberos TGTs for any domain user with any privilege level.

Identity attack chain#075	GDPR#076
Sequential attack stages: Reconnaissance → Initial access → Privilege escalation → Lateral movement → Persistence → Impact.	EU Regulation 2016/679. Global baseline for data protection. Applies extraterritorially to any org processing EU residents' data.

Session hijacking#073	STRIDE#074
Stealing a valid authenticated session token and using it to impersonate the legitimate user without re-authenticating.	Microsoft threat classification: Spoofing · Tampering · Repudiation · Information Disclosure · Denial of Service · Elevation of Privilege.

Data Protection by Design	#079	DPIA — Data Protection Impact Assessment	#080
GDPR Article 25 obligation: privacy-protective design choices must be made from the architecture phase.		Structured risk assessment of how a proposed processing activity affects individuals' privacy. Mandatory for high-risk processing (GDPR Art. 35).	

Data minimisation#077	Privacy by Design#078
Collect and process only the personal data necessary for the stated purpose. Foundational GDPR and IAM design principle.	Embedding privacy protections into system design from the outset, not retrofitting them. Required by GDPR Article 25.

SoD exception	#083	SOC 2 Type II	#084
Documented, approved instance where a user legitimately holds access that would normally constitute a SoD conflict, with compensating controls.		Audit report assessing both design and operating effectiveness of controls over a defined period (minimum 6 months). Most credible SOC report.	

IGA — Identity Governance & Administration#081	Access certification#082
Platforms managing access reviews, role management, SoD enforcement, policy compliance, and audit evidence at scale.	Periodic process in which managers attest that each team member's access is still appropriate and required.

Credential Vault#087	PAW — Privileged Access Workstation#088
Hardened encrypted storage for privileged passwords and secrets with automated rotation, access control, and audit logging.	A dedicated, hardened device used exclusively for privileged admin tasks — never for general activities like email or browsing.

Residual risk#085	PAM — Privileged Access Management#086
Remaining risk after controls have been applied. Must be explicitly accepted and documented.	Framework, practices, and tools for controlling, monitoring, and auditing privileged access across an environment.

UEBA — User & Entity Behaviour Analytics#091	SOAR#092
Analytics technology establishing behavioural baselines and alerting on deviations that may indicate compromise.	Security Orchestration, Automation, and Response. Enables automated execution of security playbooks in response to detected threats.

Session recording#089	ITDR — Identity Threat Detection & Response#090
Capture of a complete privileged session — all commands, actions, screen content — for forensic investigation and compliance.	Security tooling specifically designed to detect identity-based attacks: credential theft, lateral movement, privilege escalation.

APEX	NHI — Non-Human Identity
#095 AI-Powered Exposure eXchange: Assume Compromise · Prioritise Continuously · Eliminate Implicit Trust · eXchange Intelligence · Elevate Offensively.	#096 Identity of a non-person entity: service account, API key, OAuth token, managed identity, IoT device, CI/CD credential, or AI agent.

Dwell time#093	IDEAL Framework#094
Duration between initial compromise and detection. 2024 global median: 10 days. Reduced by ITDR tooling and monitoring.	Silverfort's 5-pillar identity security operating model: Integrate · Discover · Enforce · Act · Lightweight.

Shadow AI#099	Secrets management#100
AI agents deployed outside official IT oversight, without governance, proper permissions management, or monitoring.	Practice and tooling for securely storing, rotating, and controlling access to privileged credentials, API keys, and secrets used by NHIs.

Agentic AI	Prompt injection
#097 An AI system operating autonomously — interpreting instructions, planning, accessing resources, and acting without constant human oversight.	#098 Attack against agentic AI embedding malicious instructions in content the agent processes, causing unintended actions.